# Research 2026-10-21: Supabase Free / Vercel Hobby / GitHub Actions limits and ops additions (feeds phases 3 and 9)

First-party pages fetched 2026-10-21 unless marked UNV (unverified or third-party). Not checked: the live project's advisors/extension list, third-party keep-alive claims, branching on Free.

## Limits

| Area | Limit | Source |
|---|---|---|
| Supabase projects | 2 active; paused ones do not count | supabase.com/pricing |
| DB | 500 MB, shared CPU, 500 MB RAM | pricing |
| Egress | 5 GB + 5 GB cached | pricing |
| Storage | 1 GB total, max file 50 MB (cannot be raised on Free) | /docs/guides/storage/uploads/file-limits |
| Auth MAU | 50,000 | pricing |
| Realtime | 200 concurrent connections, 2M messages/month, 100 msg/s, 100 channels per connection, broadcast payload 256 KB, Postgres-change payload 1,024 KB | /docs/guides/realtime/limits |
| Edge Functions | 500k invocations/month; 256 MB; 2 s CPU per request; 150 s wall clock; 100 functions; bundle 20 MB CLI / 5 MB dashboard; outgoing ports 25 and 587 blocked; 100 secrets | /docs/guides/functions/limits |
| Auth email | built-in SMTP 2/hour and ONLY to project team members; custom SMTP starts at 30/hour | /docs/guides/auth/auth-smtp |
| Auth rate limits | sign-in 30 per 5 min per IP; refresh 150 per 5 min | /auth/rate-limits |
| Inactivity pause | after 7 days of "insufficient user database activity"; warning email ~1 week before; restore window 1 year (2024 changelog said 90 days) | /docs/guides/platform/free-project-pausing |
| Backups | none on Free (export with `supabase db dump`); Pro 7 daily backups; PITR ~100 USD/month, Pro+ | /docs/guides/platform/backups |
| Logs | 1 day Free, 7 days Pro | pricing |
| pg_cron | recommended ≤ 8 concurrent jobs, each ≤ 10 min; Free availability not stated (UNV) | /docs/guides/cron |
| DB connection | direct connection is IPv6 only; GitHub Actions is IPv4 only -> use the Supavisor session pooler (port 5432); IPv4 add-on Pro only ~4 USD/month | /docs/guides/database/connecting-to-postgres |
| MFA | TOTP free on all plans; phone MFA paid; leaked-password protection Pro+ (this corrects our earlier note "no MFA on free" — confirm in the dashboard) | search of supabase.com; /auth/password-security |
| Vercel Hobby functions | 300 s max; 2 GB / 1 vCPU; 1M invocations, 4 h active CPU, 360 GB-hrs/month | vercel.com/docs/limits (2026-09-16) |
| Vercel Hobby transfer/builds | 100 GB fast data transfer; 100 deployments/day; 1 concurrent build; runtime logs kept 1 hour | same |
| Vercel Hobby cron | once per day, up to 59 min jitter | /docs/cron-jobs/usage-and-pricing |
| Vercel Hobby commercial use | non-commercial personal use only (ads, sales, paid hosting count as commercial) | /docs/limits/fair-use-guidelines |

| Area | Limit | Source |
|---|---|---|
| Vercel Hobby, new 2026-09-16 | keeps only the 3 latest production deployments past 30 days; 10 GB deployment storage | vercel.com/changelog/hobby-projects-now-retain-fewer-deployments-to-free-up-storage |
| GitHub Actions | private repo 2,000 min/month, 500 MB artifacts; public repo standard runners free; scheduled workflows in public repos are disabled after 60 days without repo activity | docs.github.com billing |
| Pro: Supabase from 25 USD/month (8 GB DB, 250 GB egress, 100 GB storage, 7-day backups, no pausing, leaked-password protection); Vercel Pro 20 USD/month (1 TB transfer, per-minute cron, commercial use). | | |

## What breaks first

1. **Supabase Data API grants change on 2026-10-30** (supabase.com/changelog/45329): new `public` tables are no longer auto-granted to anon/authenticated/service_role; existing tables keep grants; a migration that creates a table without explicit GRANT fails with 42501. Affects `share_links`, `plan_nodes`, `decisions`, `ai_usage` and every future table. (Our 0016 only created functions, which carry explicit grants.)
2. Backups on Free: nothing exists unless we build it; dumps from GitHub Actions must use the session pooler string.
3. Pause risk: our only protection is in-DB pg_cron, which may not count as user activity (undocumented). `/auth/v1/health` does not touch Postgres (UNV).
4. Invitations to real people fail until custom SMTP or an HTTP email API / Gmail function is on (done: /api/invite on Vercel).
5. Realtime is fine for solo + a few people if each tab uses one channel. 6. The 2 s CPU limit hurts heavy work in the MCP function. The 500 MB DB is the likeliest long-term cap (audit logs, versions, embeddings). 7. Hobby is non-commercial. 8. Legacy anon/service_role JWT keys are planned for retirement by end of 2026: migrate to `sb_publishable_` / `sb_secret_` keys (/docs/guides/getting-started/migrating-to-new-api-keys); pg_net and Database Webhooks then need the secret key in the `apikey` header.

## Keep the project alive

A real read through PostgREST from OUTSIDE the DB once a day: a daily Vercel cron hitting a function that reads a tiny table, plus a GitHub Actions schedule as second source (note: scheduled workflows in a public repo self-disable after 60 days without activity). Route the pause warning email to a mailbox you read. Pro is the real fix if the project becomes important.

## Ranked additions

Phase 3: (S) GRANT in the same migration as RLS for every new table, nothing to `anon` on private tables, matrix assertion `has_table_privilege('anon', t, 'select')` is false; (S) revoke execute on every security definer function from anon/public (lints 0028/0029), definer functions outside exposed schemas with `set search_path = ''`; (S) policies use `(select auth.uid())`, `to authenticated`, index every policy column, no `user_metadata` (lint 0015), `security_invoker = true` on views (0010); (S) run get_advisors after each migration and fail CI on ERROR level; (M) pgTAP (`supabase/tests/database`, `supabase test db`) next to the DO-block matrix (which tests the live project); (S) share_links: hash, constant-time compare, rate-limited lookup RPC, expiry in the RPC, `noindex` + `Referrer-Policy: no-referrer` on that route only; (S) D1 enforced by RLS and RPC, not just the UI. Phase 9: (M) nightly backup via Actions with `supabase db dump --db-url <session-pooler>` (roles, schema, data `--use-copy`), encrypt with `age` (public key in repo, private offline), upload as artifact/release asset not

git commits, fail if dump is empty/schema-only; storage bucket separately; (M) weekly restore drill into a throwaway Postgres service container + row-count checks; (S) keep-alive as above; (S) headers in vercel.json: CSP (`default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; connect-src 'self' https://plbvgcnyfclillatpowc.supabase.co wss://plbvgcnyfclillatpowc.supabase.co; font-src 'self'; frame-ancestors 'none'; base-uri 'self'; form-action 'self'` — NOTE our app loads Google Fonts, so font/style hosts must be added; start with Report-Only), Referrer-Policy strict-origin-when-cross-origin (no-referrer on share routes), nosniff, Permissions-Policy camera/microphone/geolocation off, HSTS; `frame-ancestors` only works as an HTTP header; (S) Dependabot (npm + github-actions weekly), `npm audit --omit=dev` + osv-scanner, gitleaks-action; (S) deploy Edge Functions and migrations from CI with a scoped access token (`supabase/setup-cli@v1`, `db push --dry-run` first); (M) axe in CI via @axe-core/playwright with wcag2a/aa and 21a/aa tags; visual regression only with baselines generated on the CI OS/browser; Playwright artifacts: retention 7 days, traces only on failure (500 MB quota); (S) monitoring: free uptime ping of the MCP address; log errors to a small table (Vercel runtime logs last 1 hour on Hobby); (M) search: tsvector generated column + GIN + websearch_to_tsquery; unaccent/pg_trgm availability UNV (check Extensions list); Urdu: `simple` config; (L) pgvector: gte-small is English-only and truncates at 512 tokens (bad for Urdu); a few hundred pages need no index or HNSW; 384 floats ≈ 1.5 KB per chunk.

## Corrections to our assumptions

Context pack said "no MFA on free": TOTP is free (phone MFA paid). 9.6 "cron stops": the pause criterion is user DB activity; do not rely on in-DB cron as keep-alive. Nightly dump from the direct host fails from Actions (IPv6): use the pooler. Vercel Hobby cron is once a day. Check phase 11 for commercial intent (Hobby is non-commercial). Email from an Edge Function: ports 25/587 blocked; use an HTTPS API (our Gmail path runs on Vercel, not the Edge Function). Phase 3.4 needs grant checks (`has_table_privilege`, `has_function_privilege`) as well as RLS behaviour.